

Assessment memorandum

Subject	Bank Syariah Indonesia - May 2023 service disruption and cyber incident
Assessment	Independent public-evidence IT GRC case study
Research cut-off	13 July 2026
Purpose	Portfolio review and interview discussion
Boundary	Public observability only; no internal control-effectiveness opinion

Question assessed

What do public BSI, OJK, audited-filing, legal, regulatory, technical, and reputable media sources establish about the incident, and what control areas merit follow-up without pretending to have internal audit access?

Executive conclusion

The disruption, staged service recovery, cyber-incident indication, forensic work, regulatory coordination, and later corrective-action statement are supported by attributed public evidence. The reviewed source set does not establish a final forensic root cause, initial-access vector, verified affected-record inventory, or internal control test result. Those facts must remain unresolved unless additional evidence is obtained.

CONTROL TOTAL	RESULT	INTERPRETATION
Public sources	9	Eight primary sources and one secondary source used for attributed claim context
Incident events	7	Chronology reconstructed from issuer, regulator, filing, and Reuters reporting
Evidence claims	12	8 supported or attributed; 1 reported claim; 3 not publicly observable
Control domains	10	2 observed action; 3 partial evidence; 5 not publicly observable
Recommendations	8	Analyst proposals for a comparable regulated-bank environment; not BSI commitments

Assessment boundary

- No BSI systems were accessed, scanned, or tested.
- No internal logs, tickets, policies, contracts, control workpapers, or final forensic report were reviewed.
- A missing public disclosure is an evidence limitation, not proof of a failed control.
- No alleged leaked data was accessed, inspected, or redistributed.

1. Public incident chronology

The chronology preserves source attribution and does not convert public statements into independently measured uptime or forensic conclusions.

Date	Event	Publicly supported fact	Classification	Source
2023-05-07	IT maintenance and mitigation	BSI later stated that it conducted IT-system maintenance as a risk-mitigation step on 7 May.	Issuer statement	S-001
2023-05-08	Customer access disruption	BSI stated that customers experienced difficulty accessing services on 8 May and that normalization proceeded in stages; the year-end filing records that operations were affected by a cyber incident on this date.	Confirmed public fact	S-001;S-003
2023-05-09	Branch and ATM access restored in stages	BSI stated that branch and ATM transactions were available and basic BSI Mobile functions began returning gradually on 9 May.	Issuer statement	S-001
2023-05-11	Issuer reports channel recovery	BSI reported branch, ATM, and mobile-banking services as normal and stated that capacity for core banking and critical channels had been increased.	Issuer statement	S-001
2023-05-11	Cyber-incident indication disclosed	BSI stated that it found indications of a cyberattack, temporarily switched off several channels, and required audit and digital forensics for further proof.	Issuer statement with explicit caveat	S-001
2023-05-13	Regulator confirms progressive normalization	OJK stated that services had become normal in stages, continued supervisory coordination, and requested acceleration of the forensic audit.	Confirmed public fact	S-002
2023-05-16	External breach claim reported	Reuters reported LockBit's claim concerning customer records; BSI did not confirm a data leak and stated that recovery, audit, and mitigation work was continuing.	Reported third-party claim	S-004

Reviewer note

The interval between 8 and 11 May is not treated as measured downtime. BSI's 11 May normal-service wording and OJK's 13 May progressive-normalization wording are retained as separate observations from different dates and viewpoints.

2. Evidence claim register

Reported claims and non-observable facts are kept outside confirmed-fact counts. Analyst treatment states the safe use of each claim.

ID	Category	Claim	Classification	Confidence	Analyst treatment
C-001	Service availability	Bank operations were disrupted on 8 May 2023.	Confirmed public fact	High	Use as established incident fact
C-002	Service recovery	Branch and ATM access returned in stages by 9 May according to BSI.	Issuer statement	Medium	Attribute to BSI and do not treat as independently measured availability
C-003	Service recovery	BSI reported branch, ATM, and mobile-banking services as normal on 11 May.	Issuer statement	Medium	Attribute to BSI; retain OJK's 13 May progressive-normalization wording as separate evidence
C-004	Incident identification	BSI reported indications of a cyberattack and temporary switch-off of several channels.	Issuer statement with caveat	High	Accept the disclosed indication but do not infer attack vector or root cause
C-005	Investigation	A forensic audit was in progress and OJK requested that it be accelerated.	Confirmed regulator statement	High	Use as evidence of an investigation action only; outcome is not public in the reviewed sources
C-006	Regulatory coordination	OJK's IT supervisory and examination team coordinated with BSI and evaluated the disruption source.	Confirmed regulator statement	High	Use as evidence of regulator engagement
C-007	Post-incident action	BSI's year-end filing states that corrective action was taken and cybersecurity was enhanced.	Management statement in audited filing	Medium	Do not infer which controls changed or whether they operated effectively
C-008	Financial impact	Management stated that the incident had no material impact on the bank's financial performance.	Management statement in audited filing	Medium	Present as management's materiality view rather than independent impact measurement
C-009	Alleged data exposure	Reuters reported LockBit's claim that customer account details had been published; BSI did not confirm the alleged leak in that report.	Reported third-party claim	Medium	Keep clearly attributed and exclude from confirmed-fact counts
C-010	Root cause	The reviewed public sources do not disclose a final forensic root cause or confirmed initial-access vector.	Not publicly observable	Not assessable	Do not speculate about phishing vulnerabilities malware path or staff action
C-011	Data population	The reviewed primary sources do not publish a verified count or complete inventory of affected personal-data records.	Not publicly observable	Not assessable	Do not present attacker-supplied numbers as verified
C-012	Control effectiveness	The reviewed public sources do not contain control test workpapers audit results or evidence sufficient to conclude that specific internal controls were effective or ineffective.	Not publicly observable	Not assessable	Assess public observability only - not control effectiveness

3. Control observability working paper

This working paper compares public evidence with regulatory or technical expectations. It does not test design or operating effectiveness.

ID	Domain	Reference expectation	Public evidence	Status	Conclusion
O-001	Disaster recovery	Maintain, test, and review a disaster recovery plan for critical applications and infrastructure under POJK Article 18 and NIST recovery guidance.	Public statements describe staged restoration, but no disaster-recovery plan, test result, RTO, or RPO is published in the reviewed sources.	Not publicly observable	No conclusion on control effectiveness
O-002	Cyber risk identification	Identify cyber assets, threats, and vulnerabilities under POJK Article 21 and SEOJK Sections II-III.	The public incident disclosures do not include an asset, threat, vulnerability, or dependency assessment.	Not publicly observable	No conclusion on control effectiveness
O-003	Cyber maturity assessment	Perform and report cyber-risk and cybersecurity-maturity self-assessments under POJK Article 22 and SEOJK Sections II-IV.	No assessment result or maturity score is included in the reviewed public incident sources.	Not publicly observable	No conclusion on control effectiveness
O-004	Security testing	Conduct periodic vulnerability-based and annual scenario-based cybersecurity testing under POJK Articles 23-25 and SEOJK Sections V-VI.	No vulnerability-test or scenario-test evidence is published in the reviewed sources.	Not publicly observable	No conclusion on control effectiveness
O-005	Detection and containment	Detect cyber incidents and perform containment and recovery actions under POJK Article 21 and NIST incident-response guidance.	BSI disclosed cyberattack indications and a temporary switch-off of several channels, but detection timestamps, telemetry, and containment criteria are not public.	Partial public evidence	Action is visible but effectiveness is not assessable
O-006	Forensic investigation and coordination	Investigate incidents, preserve evidence, and coordinate with regulators and relevant parties under SEOJK and NIST guidance.	BSI disclosed audit and digital-forensic work; OJK confirmed ongoing coordination and requested acceleration of the forensic audit.	Observed public action	Action is evidenced but audit scope and outcome are not public
O-007	Service recovery	Restore impaired services using prioritized and tested recovery procedures under POJK Article 18 and NIST recovery guidance.	BSI and OJK published staged recovery statements between 9 and 13 May; no independently measured service-level data or recovery-test evidence is public.	Partial public evidence	Recovery activity is visible but recovery capability is not fully assessable
O-008	Personal-data protection	Protect personal data and perform impact assessment under POJK Articles 43-45 and Indonesia's PDP Law.	BSI stated customer data were safe while Reuters reported an unverified attacker claim; no public data-impact assessment is included in the reviewed primary sources.	Not publicly observable	Do not conclude breach scope or privacy-control effectiveness
O-009	Stakeholder communication	Coordinate accurate incident and recovery communication under OJK supervisory expectations and NIST guidance.	BSI issued recovery statements and an apology; OJK issued a public update and referred to customer complaints and communication.	Observed public action	Communication occurred; completeness and timeliness are not independently scored
O-010	Post-incident improvement	Use forensic findings and lessons learned to improve systems, controls, and recovery planning under POJK Articles 25-26 and NIST guidance.	The year-end filing states that corrective actions were taken and cybersecurity enhanced, without publishing implementation evidence or closure testing.	Partial public evidence	Improvement is stated but design and operating effectiveness remain unverified

4. Recommendation register

All actions below are analyst proposals for a comparable regulated-bank environment. They are not attributed to BSI and are not BSI commitments.

ID	Pri	Horizon	Domain	Recommendation	Expected evidence	Suggested owner
R-001	P1	0-30 days	Forensic governance	Create a sanitized post-incident report that separates confirmed facts, disputed claims, root cause, impact, actions, and unresolved items.	Approved sanitized post-incident report and claim register	CISO / IT Risk / Legal / Corporate Communications
R-002	P1	0-30 days	Audit evidence	Build a forensic closure pack with evidence chain, affected-system scope, remediation owners, validation tests, and formal risk acceptance for unresolved items.	Evidence index, closure memo, and independent validation record	CISO / Internal Audit / IT Operations
R-003	P1	0-30 days	Recovery	Document channel-specific RTO and RPO, actual restoration timestamps, dependencies, manual workarounds, and customer-impact metrics.	Recovery scorecard for branch, ATM, mobile, and core dependencies	IT Operations / BCM / Business Owners
R-004	P1	31-90 days	Security testing	Run a regulator-aligned ransomware scenario exercise covering detection, isolation, clean-room recovery, data validation, communications, and evidence capture.	Exercise plan, results, lessons learned, and tracked corrective actions	CISO / SOC / BCM / Third Parties
R-005	P1	0-30 days	Data protection	Complete a documented personal-data impact assessment and reconcile any externally reported data claim against verified records and notification duties.	Data-impact assessment, decision log, and notification evidence	Data Protection / Legal / CISO
R-006	P2	31-90 days	Incident communication	Define a single incident-status taxonomy and evidence-based approval workflow for customer, regulator, investor, and media updates.	Communication matrix, approval workflow, and status definitions	Corporate Communications / Legal / Incident Commander
R-007	P2	31-90 days	Third-party resilience	Map critical service dependencies and contractually test escalation, evidence sharing, and recovery support with material technology partners.	Dependency map, contact tree, contract-control checklist, and joint test result	Vendor Risk / IT Operations / Procurement
R-008	P2	31-90 days	Management oversight	Create a board-level lessons-learned dashboard covering detection time, containment time, restoration by channel, evidence closure, customer complaints, and overdue actions.	Monthly incident-improvement dashboard with accountable owners	Board Risk Committee / CIO / CISO / Internal Audit

Closure principle

A written policy alone is not closure. Closure requires implementation evidence, validation results, accountable approval, and explicit acceptance of remaining risk.

5. Source register and limitations

ID	Publisher	Date	Type	Locator	Primary use
<u>S-001</u>	PT Bank Syariah Indonesia Tbk	2023-05-11	Issuer disclosure	Press release, pp. 1-2	Issuer timeline, service restoration statement, cyber-incident indication, and forensic-audit caveat
<u>S-002</u>	Otoritas Jasa Keuangan	2023-05-13	Regulator release	Press release SP-51/OJK/GKPB/V/2023, p. 1	Regulator status, forensic-audit request, supervisory coordination, and customer-complaint expectations
<u>S-003</u>	PT Bank Syariah Indonesia Tbk	2024-01-30	Audited filing	Note 47(f) - Other Significant Information	Year-end disclosure of the 8 May cyber incident, corrective actions, cybersecurity enhancement, and management's financial-impact view
<u>S-004</u>	Reuters	2023-05-16	Independent reporting	Article body	Independent reporting of the LockBit claim and BSI's response; claim is not treated as verified fact
<u>S-005</u>	Otoritas Jasa Keuangan	2022-07-06	Regulation	Articles 18, 21-26, and 43-45	Binding Indonesian banking IT governance, cyber resilience, recovery, testing, and data-protection requirements
<u>S-006</u>	Otoritas Jasa Keuangan	2022-12-27	Regulatory guidance	Sections II-IX and Appendices I-VI	Cyber-risk assessment, maturity, testing, incident reporting, and evidence expectations for banks
<u>S-007</u>	Government of Indonesia	2022-10-17	Law	Act text	Personal-data protection duties and breach-response context
<u>S-008</u>	National Institute of Standards and Technology	2025-04-03	Technical standard	CSF 2.0 Community Profile	Current incident-response lifecycle and governance reference
<u>S-009</u>	National Institute of Standards and Technology	2016-12-22	Technical standard	Publication overview	Recovery planning, playbooks, testing, metrics, and lessons-learned reference

Method

Register sources -> classify claim authority -> reconstruct events -> preserve conflicting wording -> map control expectations -> assess public observability -> propose required evidence and accountable follow-up.

Limitations

- Issuer and management statements are attributed and are not independent cyber assurance.
- Service-recovery statements are not independent availability measurements.
- The source set does not include a published final forensic report or verified affected-record inventory.
- Later disclosures may change the evidence set and should be added as new source records.